

INTERN DOCUMENT — niet publiceren. Bewaren zolang de verwerking plaatsvindt.

AVG art. 35 — versie 1.1 — 4 juli 2026

Verwerkingsverantwoordelijke: Dennis van Westbroek · KVK 74667653 · info@perfectsupplement.nl

DPIA — PerfectSupplement Leefstijlcheck

0. Waarom deze DPIA verplicht is

De verwerking voldoet aan meerdere criteria die een DPIA verplicht maken (AVG art. 35 lid 3 + AP-lijst):

- **Bijzondere persoonsgegevens** (gezondheidsgegevens, AVG art. 9) worden op grote schaal verwerkt.
- **Systematische, geautomatiseerde beoordeling** (scoring-engine → domeinscores, profiellabel, urgentieniveau).
- **Profilering** als basis voor gepersonaliseerde content en e-mail.

Conclusie: DPIA is verplicht en hierbij uitgevoerd.

1. Systematische beschrijving van de verwerking

1.1 Doel

Gebruikers leefstijl-inzicht geven op zes domeinen (slaap, energie, stress, voeding, beweging, herstel) en daarop afgestemde, niet-medische leefstijl- en supplementinformatie aanbieden. **Uitdrukkelijk geen** diagnose, monitoring of behandeling (zie COMPLIANCE.md, beoogd doel = algemeen welzijn/leefstijl-educatie).

1.2 Categorieën betrokkenen

Volwassen websitebezoekers (doelgroep mannen ±40+) die vrijwillig de Leefstijlcheck invullen. Geen verzameling onder 16 jaar (privacyverklaring §kinderen).

1.3 Categorieën persoonsgegevens

Categorie	Voorbeeld	Bijzonder (art. 9)?
Intake-antwoorden	answers (jsonb), symptom_profile	Ja — gezondheidsgegevens
Afgeleide scores	domain_scores, urgency_level, profile_label	Ja — afgeleide gezondheidsgegevens
Leeftijdsindicatie	age_range	Nee
Contact/marketing	marketing_email, reminder-e-mail	Nee (wel gekoppeld aan art. 9)
Voeding/check-in/gewicht	periodieke rapportage, eiwitrichtlijn	Ja

Categorie	Voorbeeld	Bijzonder (art. 9)?
Accountkoppeling	psf_account (HMAC bearer-token)	Nee (identificator)
Gedrag	affiliate_clicks, webanalyse	Nee

1.4 Ontvangers / verwerkers (bron: privacyverklaring)

Verwerker	Rol	Locatie / waarborg
Supabase	Database / hosting	EU (Frankfurt)
Resend	Transactionele/nurture e-mail	VS — EU-US Data Privacy Framework
Webanalyse	Analytics	VS — DPF
CRM	E-mailmarketing	EU
Hetzner	VPS-hosting (app)	EU (zie infra-doc)

Verwerkersovereenkomsten: "waar nodig gesloten" → **[VUL IN]** bevestig per verwerker dat een geldige verwerkersovereenkomst (art. 28) is getekend en archiveer ze.

1.5 Bewaartermijnen (technisch afgedwongen, geautomatiseerd)

Gegeven	Termijn
Intake-sessies (incl. art. 9)	24 maanden, automatisch verwijderd
Reminders	12 maanden na verzending
Nurture/marketing	5 jaar na intrekking
Feedback	1 jaar
Affiliate clicks	90 dagen
Webanalyse	14 maanden

Bij intrekking van toestemming worden gezondheidsgegevens **geanonimiseerd of verwijderd** (consent-tekst + privacyverklaring).

1.6 Internationale doorgifte

Doorgifte buiten de EER alleen met DPF of door de EC goedgekeurde SCC's (privacyverklaring §doorgifte).

2. Rechtsgrond, noodzaak en evenredigheid

- **Rechtsgrond:** AVG art. 9 lid 2 sub a (**uitdrukkelijke toestemming**) voor bijzondere gegevens, in combinatie met art. 6 lid 1 sub a. Bevestigd in privacyverklaring en consent-texts.ts.

- **Toestemming is granulair en specifiek per doel** — aparte toestemmingen voor: supplementadvies, anonieme productanalyse, nurture-e-mail, voedingsrapportage, domein-check-in, gewicht/eiwitrichtlijn, bewaren onder e-mailadres, hermeting-reminder, contactformulier. Elke tekst bevat *"geen medisch advies en geen diagnose; ik kan dit altijd intrekken"*.
- **Vrij & intrekbaar:** toestemming wordt aan het einde van de check gevraagd (geen vooraf-aangevinkte vakjes — [VUL IN] verifieer dat opt-in standaard uit staat), en is op elk moment intrekbaar via uitschrijflink/instellingen.
- **Dataminimalisatie:** alleen leefstijl-relevante antwoorden; geen NAW behalve e-mail bij expliciete opt-in; age_range i.p.v. exacte geboortedatum.
- **Evenredigheid:** verwerking staat in verhouding tot het doel (leefstijl-inzicht); geen minder ingrijpend alternatief levert hetzelfde inzicht.

3. Risicobeoordeling voor betrokkenen

#	Risico	Kans	Impact	Maatregel
R1	Ongeoorloofde toegang tot gezondheidsgegevens	Laag	Hoog	RLS aan, HTTPS, encryptie-at-rest, HMAC bearer-token met issued-at+expiry
R2	Datalek bij verwerker	Laag	Hoog	EU-hosting (Supabase Frankfurt), DPF/SCC, verwerkersovereenkomsten
R3	Onnodig lange bewaring	Laag	Middel	Geautomatiseerde, technisch afgedwongen retentie + anonimisering bij intrekking
R4	Functie-creep: scores/labels gelezen als medische beoordeling	Middel	Hoog	Disclaimers (intake/dashboard/artikel), urgency_level niet user-facing, compliance-tests tegen diagnose-taal (*-assessment.test.ts, nurture-copy guard), beoogd-doel vastgelegd in COMPLIANCE.md
R5	Toestemming niet vrij/specifiek/geïnformeerd	Laag	Hoog	Granulaire opt-in per doel, geen pre-check, intrekbaar, art. 9-melding in UI
R6	Re-identificatie van "geanonimiseerde" data	Laag	Middel	[VUL IN] bevestig dat anonimisering onomkeerbaar is (geen koppelsleutel behouden)
R7	Profilering benadeelt betrokkene	Laag	Middel	Geen geautomatiseerde besluiten met rechtsgevolg (art. 22); output is informatief/vrijblijvend

4. Maatregelen (samenvatting)

Technisch: RLS, HTTPS, encryptie, HMAC-token (issued-at/expiry), geautomatiseerde retentie, anonimisering bij intrekking, compliance-testsuite tegen diagnose-/ziektetaal in gepersonaliseerde output.

Organisatorisch: granulaire toestemming per doel, privacyverklaring + medische disclaimer, EFSA-claimregister voor supplementcommunicatie, vastgelegd niet-medisch beoogd doel, verwerkersovereenkomsten.

5. Restrisico & conclusie

Met bovenstaande maatregelen is het restrisico **laag**, op voorwaarde dat de [VUL IN]-punten zijn afgehandeld. Het hoogste resterende aandachtspunt is **R4 (functie-creep richting medische interpretatie)** — dit is geen datalek-risico maar een kwalificatie-/claimrisico, en wordt structureel beheerst via de compliance-tests en disclaimers. Voorafgaande raadpleging van de AP (art. 36) is **niet** nodig zolang het restrisico laag blijft.

6. Open punten voor vaststelling [VUL IN]

- ☐ Verwerkingsverantwoordelijke: rechtspersoon + contactgegevens
- ☐ Functionaris Gegevensbescherming (FG): aangesteld? zo ja, contact; zo nee, onderbouwing waarom niet verplicht
- ☐ Verwerkersovereenkomsten (art. 28) getekend & gearhiveerd per verwerker (Supabase, Resend, analytics, CRM, Hetzner)
- ☐ Bevestiging: anonimisering bij intrekking is onomkeerbaar
- ☐ Bevestiging: toestemmingsvakjes standaard uit (geen pre-check)
- ☐ Procedure datalekmelding (art. 33/34) vastgelegd
- ☐ Datum periodieke herziening DPIA (advies: jaarlijks of bij wezenlijke wijziging)

7. Vaststelling

Rol	Naam	Datum	Akkoord
Verwerkingsverantwoordelijke	[VUL IN]		
FG / adviseur	[VUL IN]		